

MÓDULO 3 · DOSSIER 04

Bits de seguridad

Los bits de seguridad aproximan el costo del mejor ataque conocido, no la longitud visible de un parámetro.

Material elaborado por el profesor Sergio Gevatschnaider

Fuente curricular verificable · SHA-256 871ef4420fae

Contenido

Propósito	3
Resultados de aprendizaje	3
Núcleo teórico	3
Impacto cuántico	3
Tabla orientativa	3
Ejemplo de cálculo	3
Profundización y criterio profesional	4
Caso de análisis	4
Entrega esperada	4
Riesgos y errores frecuentes	4
Actividades de dominio	4
Lista de comprobación	4
Referencias seleccionadas	4

Propósito

Los bits de seguridad aproximan el costo del mejor ataque conocido, no la longitud visible de un parámetro.

Resultados de aprendizaje

1. interpretar 2^k y costo medio.
2. comparar seguridad de claves, hashes y contraseñas.
3. incorporar horizonte y transición.

Núcleo teórico

Para una clave ideal de k bits existen 2^k candidatos. Una búsqueda exhaustiva clásica necesita, en promedio, aproximadamente 2^{k-1} pruebas.

Los bits de seguridad representan el costo logarítmico del mejor ataque conocido. No tienen por qué coincidir con:

- longitud nominal de clave;
- longitud de una contraseña;
- tamaño de una salida hash;
- cantidad de caracteres;
- parámetros de un algoritmo.

Una contraseña humana larga puede tener poca entropía si sigue patrones. Derivar 256 bits desde ella no crea 256 bits de incertidumbre.

Impacto cuántico

Grover ofrece una aceleración cuadrática idealizada para búsqueda no estructurada. Shor amenaza factorización y logaritmo discreto, por lo que afecta RSA, DH y ECC.

Tabla orientativa

Nivel clásico aproximado	Lectura didáctica	Ejemplos y cautelas
56 bits	Insuficiente	DES puede recorrerse por fuerza bruta
80 bits	Heredado	No apropiado para protección nueva
112 bits	Margen clásico heredado	Debe evaluarse según vida útil y política de transición
128 bits	Objetivo moderno común	AES-128 y curvas correctamente elegidas se sitúan en este orden
192 bits	Margen alto	Mayor costo y tamaños; no corrige un protocolo defectuoso
256 bits	Margen muy alto clásico	AES-256 o clave ChaCha20; la seguridad del sistema puede ser menor

NIST SP 800-57 relaciona fortaleza, algoritmo, tamaño de clave y período de protección. No debe interpretarse una fila como garantía atemporal: el horizonte, la sensibilidad, la implementación y las transiciones normativas importan.

Ejemplo de cálculo

Si un atacante prueba r candidatos por segundo, recorrer un espacio ideal de 2^k tarda en promedio:

$$\text{tiempo medio} \approx 2^{k-1} / r$$

La fórmula solo describe fuerza bruta ideal. No modela sesgos humanos, ataques de canal lateral, reducción del espacio por estructura ni errores del protocolo.

Profundización y criterio profesional

Para búsqueda exhaustiva ideal, k bits implican 2^k candidatos y aproximadamente $2^{(k-1)}$ pruebas en promedio. En hashes, la resistencia a colisiones de una salida de n bits se aproxima a $2^{(n/2)}$ por el efecto cumpleaños, mientras preimagen se aproxima a 2^n bajo el modelo ideal.

Los tamaños nominales no son comparables entre familias: RSA-3072, una curva de 256 bits y AES-128 pueden perseguir un orden clásico semejante mediante supuestos y ataques diferentes. Las contraseñas dependen de distribución humana, no del ancho de la salida de la KDF.

Grover ofrece una aceleración cuadrática idealizada para búsqueda no estructurada; no equivale a dividir mecánicamente toda métrica del sistema. Shor cambia cualitativamente RSA, DH y ECC. El inventario y la vida útil del dato deben preceder la migración.

Caso de análisis

Compare un PIN de seis dígitos derivado a 256 bits, AES-128 y un hash de 256 bits frente a preimagen y colisión. Explique por qué los números visibles no son una medida común.

Entrega esperada

Documento activos, actores, propiedad, parámetros, flujo, condición de fallo y decisión recomendada. Separe siempre la garantía criptográfica de la garantía operativa.

Riesgos y errores frecuentes

- igualar longitud con entropía.
- ignorar ataques estructurales.
- presentar 112 bits como recomendación eterna.

Actividades de dominio

1. ¿Por qué colisión y preimagen tienen costos distintos?
2. ¿Qué significa seguridad efectiva?
3. ¿Cómo cambia la decisión si el dato debe permanecer secreto veinte años?

Lista de comprobación

- Puedo definir la propiedad y el adversario.
- Puedo explicar parámetros, límites y supuestos.
- Puedo detectar al menos tres configuraciones inseguras.
- Puedo justificar una decisión de arquitectura.
- Puedo relacionar el tema con una norma o especificación primaria.

Referencias seleccionadas

1. NIST SP 800-57 Part 1 Rev. 5 - <https://doi.org/10.6028/NIST.SP.800-57pt1r5>
2. NIST SP 800-131A Rev. 2 - <https://doi.org/10.6028/NIST.SP.800-131Ar2>